TRABALHO 1 • ENGENHARIA DE SOFTWARE ADVERSARIAL

Modelagem Adversarial no ELO: Concessão e Resgate de Recompensas

Análise estratégica de incentivos conflitantes, superfície de ataque e robustez arquitetural.

🎯 Delimitação da Interação Analisada

Escopo Específico: Concessão de pontos/cupons na compra física e a posterior solicitação e validação de resgate de recompensas no app.

Por que é Adversarial (não mero erro): Atores racionais operam de forma estratégica para maximizar utilidade explorando regras do sistema.

🛡️ Ativos Críticos a Preservar

- **Distribuição Correta de Recursos:** Evitar esgotamento indevido de prêmios físicos da loja.
- **Confiança Mútua:** Garantir que pontos acumulados legitimamente sejam honrados pelo comerciante.

📱 Aplicativo em Produção na Google Play: **Cardial ELO (Indiki)** ↗

SEÇÃO 3.1 • DESCRIÇÃO DO SISTEMA

Mapeamento dos Atores e Pressupostos

Capacidades, assimetrias observáveis e pressupostos que podem falhar no ecossistema:

Ator	Objetivo Principal	Ações / Capacidades	Informações Observáveis	Restrições / Custos
Cliente (Consumidor)	Maximizar recompensas gastando o mínimo possível.	Comprar, acumular saldo de pontos e solicitar resgate de brindes no app.	Saldo de pontos, catálogo e estoque de prêmios, regras ativas.	Desembolso financeiro real, tempo e risco de ter brinde negado.
Lojista (Comerciante / Caixa)	Maximizar faturamento e retenção contendo custo de prêmios.	Gerar QR Code/pontuação, cadastrar regras, aprovar/rejeitar resgate.	Histórico de compras do cliente, solicitações pendentes, estoque físico.	Custo financeiro dos brindes, tempo no caixa, perda de reputação.

⚠️ Pressuposto 1: Integridade da Compra

O sistema assume que a compra que gerou pontos é definitiva. *Falha:* O cliente devolve o produto na loja física após resgatar o brinde (Return Scam).

⚠️ Pressuposto 2: Boa-fé do Lojista

Assume que o lojista entregará o brinde se o cliente cumprir a meta. *Falha:* Lojista clica em "Rejeitar" alegando falta de estoque (Brinde Isca).

SEÇÃO 3.2 • MODELO ESTRATÉGICO ESTÁTICO

Jogo 2×2 com Escala de Preferências (0 a 3)

Payoffs representam ordem de preferência: 3 = Melhor, 2 = Bom, 1 = Ruim, 0 = Pior. Par: `(Payoff Cliente, Payoff Lojista)`.

Cliente \ Lojista	B_1: Lojista Flexível (Confiante / Ágil no Caixa)	B_2: Lojista Defensivo (Desconfiado / Rigoroso)
A_1: Cliente Honesto (Compra e resgata de boa-fé)	`(2, 3)` **Ideal:** Cliente ganha brinde (2); Lojista fideliza com agilidade (3 - Melhor).	`(1, 1)` **Atrito:** Burocracia, atraso e desconfiança frustram ambos (1 para cada).
A_2: Cliente Malandro (Golpe da Devolução sem estorno)	`(3, 0)` **Exploração:** Cliente leva brinde grátis (3 - Melhor); Lojista tem prejuízo total (0 - Pior).	`(0, 2)` **Bloqueio:** Trapaça barrada no app (0 - Pior); Lojista salva o estoque (2).

Melhores Respostas e Equilíbrio: Se Lojista for Flexível (B_1), Cliente prefere burlar (A_2, pois nota 3 > 2). Se Lojista for Defensivo (B_2), Cliente prefere ser Honesto (A_1, pois nota 1 > 0). Se Cliente for Honesto (A_1), Lojista prefere ser Flexível (B_1, pois nota 3 > 1). Se Cliente for Malandro (A_2), Lojista prefere ser Defensivo (B_2, pois nota 2 > 0).

👉 Ausência de Equilíbrio de Nash em estratégias puras: o sistema gera oscilação cíclica contínua.

SEÇÃO 3.3 • MODELO ESTRATÉGICO DINÂMICO

O Ciclo Adaptativo em Rodadas Repetidas

Transformando a análise estática em dinâmica: Ação → Resposta → Observação → Adaptação.

Rodada	Ação do Participante (Cliente)	Resposta do Sistema / Lojista	O que se torna Observável?	Adaptação p/ Rodada Seguinte
1	Realiza compras normais e acumula pontos de boa-fé.	Lojista pontua no caixa e aprova o resgate do brinde no app sem burocracia.	O cliente percebe que o sistema não audita a permanência da compra física.	O cliente descobre que pode comprar itens caros para resgatar brinde e devolver depois.
2	**Ataque Return Scam:** Compra item de R$ 300, resgata o brinde no app e devolve o item na loja.	Loja devolve o dinheiro no caixa físico (sem integração no ELO), ficando no prejuízo do brinde.	Lojista observa estoque de brindes drenado sem faturamento retido correspondente.	O lojista adota postura punitiva e passa a rejeitar resgates de brindes de alto valor no app.
3	Cliente tenta novo resgate; clientes honestos também solicitam seus prêmios.	Lojista clica em `decisao: 'rejeitada'` indiscriminadamente para conter perda de estoque.	Clientes observam que a regra do app não é confiável; perda de reputação da loja.	**Corrida Armamentista:** Clientes abandonam o app; sistema exige redesenho com escrow.

SEÇÃO 3.3 • RESPOSTAS OBRIGATÓRIAS DA DINÂMICA

Propriedades do Modelo Dinâmico

Como a assimetria e a observabilidade alimentam a corrida armamentista:

👁️ Quem observa quem?

O cliente observa a velocidade de aprovação e o estoque no app. O lojista observa o volume de pontos emitidos e as solicitações de resgate no dashboard.

⚡ O que dispara a adaptação?

Perda financeira percebida pelo lojista (estoque zerado) ou recusa injustificada percebida pelo cliente (brinde negado após esforço).

💰 Custos da Adaptação para Cada Lado

Custo do Lojista: Tempo gasto investigando clientes e perda de clientes legítimos por fricção excessiva.

Custo do Cliente: Desgaste na relação comercial e pontos retidos sem recompensa.

⚔️ Ponto da Corrida Armamentista

Surge quando o lojista tenta se proteger com regras arbitrárias e o cliente desenvolve novas técnicas (ex: concentrar compras familiares em uma única conta para esgotar estoques) para contorná-las.

SEÇÃO 3.4 • AMEAÇAS E RISCOS

Matriz de Riscos Adversariais (Escala 1 a 3)

Cenários mapeados: Probabilidade (1 a 3) × Impacto (1 a 3) = Risco (1 a 9).

ID	Cenário de Ameaça (Formato da Norma)	Ponto de Exploração	Ativo Afetado	Prob.	Imp.	Risco
A1	Um **cliente** realiza **devolução no balcão sem estorno** aproveitando **desconexão entre PDV e ELO**, causando **prejuízo material**.	Fluxo de devolução física sem webhook no ELO	Estoque de prêmios / Margem do lojista	3	3	9 (Crítico)
A2	Um **cliente** realiza **esgotamento de brinde por compra única (Hit-and-Run)** aproveitando **falta de requisito de recorrência**, causando **prejuízo na retenção de clientes**.	Regras de resgate no `recompensasController.js`	Estoque de prêmios / Retenção do lojista	3	2	6 (Médio)
A3	Um **lojista** realiza **recusa arbitrária de brinde** aproveitando o endpoint `processarSolicitacao`, causando **quebra de confiança**.	Poder discricionário na rota `PUT /solicitacoes`	Credibilidade da moeda de fidelidade	2	3	6 (Médio)

Superfície de Ataque Mapeada: Interfaces do caixa (emissão de compra), endpoint de claim (`/compra`), painel de decisão discricionária (`/solicitacoes/processar/:id`) e ausência de barramento de eventos fiscais (NFC-e/SAT).

SEÇÃO 3.4 & 7 • ANÁLISE DA AMEAÇA PRIORITÁRIA

Aprofundamento na Ameaça A1 e Pergunta Final

Análise exaustiva da Fraude de Devolução sem Estorno (Risco 9):

🚨 Resposta do Sistema & Adaptação do Adversário

- **Resposta do Sistema:** Impor retenção de saldo (carência de 7 dias antes de liberar pontos para resgate).
- **Informação Revelada:** O cliente descobre exatamente o prazo de liberação do saldo.
- **Adaptação do Adversário:** O cliente busca itens com prazos maiores de troca (garantia estendida) ou compra em lojas sem carência configurada.
- **Dano Colateral em Usuários Honestos:** Clientes legítimos perdem a gratificação instantânea, tendo que esperar 7 dias para usar seus pontos.

❓ Resposta à Pergunta Final do Enunciado

"Depois que o sistema responder, o que o outro lado aprenderá e tentará fazer em seguida?"

O adversário aprende que o sistema não consegue verificar notas em tempo real. Em seguida, ele migrará para **consolidação familiar de contas** ou explorará lojas parceiras menores com caixas menos informatizados para burlar o limite.

Risco Residual: Conluio presencial com o atendente do caixa emitindo compras fictícias.

SEÇÃO 5 • PLANEJAMENTO P/ TRABALHO 2

Redesenho e Resiliência Arquitetural

Especificação das contramedidas concretas que serão implementadas em código no Trabalho 2:

🛡️ Mecanismos de Defesa Arquitetural

- **Módulo de Escrow de Pontos:** Status `pendente` temporário para transações acima de R$ 100 com liberação condicionada.
- **Requisito de Recorrência Mínima:** Exigir compras em pelo menos 3 datas distintas para liberar prêmios de alto valor, neutralizando caçadores pontuais (Hit-and-Run).
- **Resgate Automatizado com Trava de Estoque:** Retirada da discricionariedade manual do lojista; aprovação automática caso haja estoque provisionado.

📋 Alinhamento com os Critérios de Avaliação

- **Continuidade Garantida:** As regras propostas são viáveis de implementar diretamente nas rotas e models existentes do `back-elo`.
- **Preservação do Ativo:** Mantém a atratividade do app para os clientes honestos e a segurança financeira para os lojistas.
- **Declaração de IA:** O modelo conceitual e código foram desenvolvidos e validados pela equipe acadêmica.